6

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad _____ Grup _____ Tarih _____

Senaryo: Saat **10:15**. WSR 500'ün servis hesabına gece 03:00'te tanınmayan bir konumdan giriş yapılmış. PLC konfigürasyonu değişmiş olabilir; **kapı kilidi ve ışık perdesi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıttır**. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır, ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Kimi arayacağım: emniyet sorumlusu, OT/siber güvenlik sorumlusu ve bakım şefi; üretici servisini de haberdar ederim. İlk üç eylem: (1) emniyet doğrulanana kadar makineyi kontrollü durdurmak, (2) uzak erişimi kesip servis hesabını kapatmak, (3) kanıtı korumak: reset yok, mevcut konfigürasyon ve logların yedeği alınır.

2. **İlk 2 saat:** Emniyet fonksiyonlarının sağlam olduğunu nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Doğrulama: ışık perdesi, kapı kilidi ve acil stop parametrelerini bilinen iyi konfigürasyonla karşılaştırırım, ardından fonksiyon testi yaparım (ışık perdesini kes, kapıyı aç, acil stopa bas); test geçmeden üretime dönülmez. Korunan kanıt: uzak erişim ve servis hesabı giriş logları (03:00 girişi), PLC konfigürasyon yedeği ve değişiklik geçmişi, HMI olay kayıtları, ağ trafiği. Kapatılan hesap: servis hesabı (admin/admin) ve paylaşılan tüm kimlik bilgileri.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Olayın kısa tanımı (şüpheli yetkisiz erişim), ne zaman fark edildiği, etkilenen ürün ve sürüm, aktif istismar şüphesi olup olmadığı ve iletişim kişisi.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem. Kim ne yapıyor?

   Kök neden: açık uzak erişim ve paylaşılan admin/admin hesabı. Etki: PLC konfigürasyonu değişti mi, emniyet fonksiyonu etkilendi mi, üretim veya yaralanma etkisi var mı. Önlem: erişim kapatıldı, hesap devre dışı, konfigürasyon geri yüklendi. Kim ne yapıyor: güvenlik sorumlusu raporu yazar, bakım emniyeti doğrular, üretici servisi düzeltmeyi hazırlar, yönetim bilgilendirilir.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Uzak erişim oturum logları, servis hesabı giriş kayıtları (IP/konum), PLC konfigürasyonu önce/sonra yedekleri, HMI/olay logları, ağ trafiği, emniyet fonksiyon test kayıtları ve kararların zaman çizgisi.

En sık hata: "Resetleyip devam edelim." O düğme kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.